System Security Plan (SSP) Summary & Control Implementation Matrix

Document Title: System Security Plan (SSP) - Executive Summary & Control Matrix
System Name: SHANA Human Resources & Payroll System (SHRPS)
System Categorization: FIPS 199 Moderate Baseline (Confidentiality: Moderate | Integrity: Moderate | Availability: Moderate)

Author: Mohsen Alipour, Junior Information System Security Officer (ISSO) / Compliance Analyst
Date: 12 November 2024
Document Status: Draft

1. Executive Summary & System Description

The **SHANA Human Resources & Payroll System (SHRPS)** is a cloud-hosted web application that stores and processes Sensitive Personally Identifiable Information (SPII), including employee social security numbers, banking details, and payroll data.

This System Security Plan (SSP) documents the security controls implemented for SHRPS in accordance with **NIST SP 800-53 Rev. 5** (*Security and Privacy Controls for Information Systems and Organizations*) to ensure compliance with federal baseline requirements and safeguard organizational assets.

2. System Information Overview

Attribute	Details
System Unique ID	SHRPS-MOD-2024
System Owner	Director of Human Resources
ISSO / Compliance Lead	Mohsen Alipour
Deployment Model	Software as a Service (SaaS) hosted in AWS GovCloud
Applicable Framework	NIST SP 800-53 Rev. 5 (Moderate Baseline)
Authorization Status	In-Development / Pre-ATO (Authorization to Operate)

3. Control Implementation Matrix (NIST SP 800-53 Rev. 5)

Family	Control ID	Control Name	Implementation Status	Control Description & Implementation Details
Access Control	**AC-2**	Account Management	**Implemented**	HR system automatically synchronizes account status with Okta Identity Provider (IdP). Accounts are created via

Family	Control ID	Control Name	Implementation Status	Control Description & Implementation Details
				role-based access control (RBAC). Terminated employees are automatically disabled within 1 hour of HR offboarding. Inactive accounts are locked after 90 days of non-use.
Access Control	**AC-7**	Unsuccessful Logon Attempts	**Implemented**	User accounts are automatically locked out for 30 minutes after 5 consecutive failed login attempts within a 15-minute window. Account lockout alerts are automatically forwarded to the SIEM.
Audit & Accountability	**AU-2**	Event Logging	**Implemented**	Operating systems, application layer events, and database queries log all authentication events, privilege escalation, file modifications, and administrative actions to AWS CloudWatch and Splunk SIEM.
Audit & Accountability	**AU-6**	Audit Record Review, Analysis, and Reporting	**Implemented**	SIEM automated rules analyze log entries in real-time. High-severity alerts (e.g., unauthorized access attempts to SPII tables) trigger automated Slack/email notifications to the Security Operations Center (SOC) team within 15 minutes.
Configuration Management	**CM-6**	Configuration Settings	**Implemented**	Baseline configurations for production environments are deployed using Infrastructure as Code (Terraform) following CIS AWS Foundations Benchmarks. Drift detection runs daily.
Identification & Authentication	**IA-2**	Identification and Authentication (Organizational Users)	**Implemented**	Multi-Factor Authentication (MFA) using FIDO2 WebAuthn / Time-based One-Time Password (TOTP) is enforced for all system users. Single Factor/Password-only login is strictly blocked at the IdP layer.

Family	Control ID	Control Name	Implementation Status	Control Description & Implementation Details
System & Communications Protection	**SC-8**	Transmission Confidentiality and Integrity	**Implemented**	All network communications in transit are encrypted using TLS 1.3. Plaintext HTTP access is disabled and redirected to HTTPS via HTTP Strict Transport Security (HSTS).
System & Communications Protection	**SC-28**	Protection of Information at Rest	**Implemented**	All S3 storage buckets and PostgreSQL databases containing SPII are encrypted at rest using AWS KMS with AES-256 keys. Encryption keys are rotated automatically every 365 days.
System & Information Integrity	**SI-2**	Flaw Remediation	**Implemented**	Automated vulnerability scanning (Qualys/AWS Inspector) runs weekly. Critical and high-severity patches are applied within 14 days of release; medium vulnerabilities are remediated within 30 days.

4. Assessment & Continuous Monitoring Plan

1. **Quarterly Access Reviews:** ISSO conducts quarterly privilege reviews (AC-2) across all admin and application roles to ensure compliance with the Principle of Least Privilege.
2. **Annual Control Testing:** A subset of controls (specifically AC, AU, and IA families) undergoes annual third-party independent assessment.
3. **Continuous Logging:** Security logs are retained in immutable AWS S3 Glacier storage for a minimum of 365 days in accordance with NIST AU-11 guidelines.